

// SECURITY KNOWLEDGE INTELLIGENCE PLATFORM

Knowledge Lab

보안 지식 인텔리전스 플랫폼

공개 보안 생태계의 기법과 노하우를 끊임없이 수집하고, 출처 · 근거 · 정책 · 버전이 끝까지 추적되는 타입드 지식으로 가공해, 검색 · API · MCP · 스킬로 제공합니다.

```
> klab query --grounded --cite "ssrf filter bypass"
```

5

수집 테마 / THEMES

6,000+

시드 URL / SEEDS

60+

추적 도구 노하우 / TOOLS

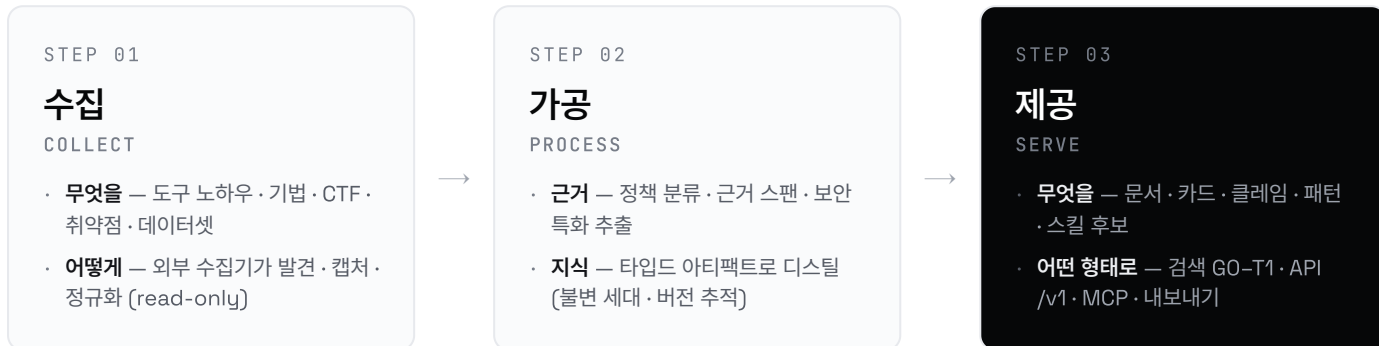
5

조회 모드 / MODES

// 01 - OVERVIEW

수집 · 가공 · 제공 — 하나의 흐름.

Knowledge Lab은 "그럴듯한 요약"을 모으는 곳이 아닙니다. 공개 보안 자료를 읽기 전용으로 가져와 출처 · 근거 스캔 · 정책 라벨 · 생성 이력 · 리뷰 상태를 보존한 뒤, 검색 · RAG · 근거 태스크 · 스킴화 · 내보내기로 제공하는 소스 기반 보안 지식 플랫폼입니다.



// FOR — 대상 사용자

- 👤 펜테스터
- 🚩 CTF 솔버
- 🔍 취약점 연구자
- 🚫 버그 헌터
- 🔗 근거가 필요한 에이전트

도구를 운영하지 않습니다. 방법과 노하우를 추적해 지식으로 만듭니다.

READ-ONLY · 수집(크롤링 · 캡처)은 별도 컴포넌트가 담당하고, Lab은 그 결과물을 매니페스트로만 가져옵니다.

IMMUTABLE · 모든 생성물은 불변이며 모델 · 프롬프트 · 스키마 · 정책 버전이 기록됩니다.

// 02 · 수집 - TOPOLOGY & THEMES

공개 출처에서 소비자까지, 읽기 전용 경계로.

공개 출처 → 수집기 → Knowledge Lab → 소비자로 이어지는 단방향 파이프라인입니다. Lab은 수집기 결과물을 읽기만 하고, 소비자는 내부 DB가 아니라 API · MCP · 내보내기만 호출합니다.



// THEMES — 무엇을 수집하나 (다섯 갈래, 도구는 그중 한 테마)

60+ tools	도구 노하우 — 도구가 쓰는 방법 · 옵션 · 워크플로우 추적 garak · PyRIT · LLM Guard · AgentDojo · Cisco MCP / Skill Scan
1,400+ research	기법 · 연구 — 익스플로잇 · 웹 · 리버싱 등 기법 문서 Project Zero · PortSwigger Research · Trail of Bits
2,700+ writeups	CTF 라이트업 — 풀이 · 노트 · 포스트모템 ctf.report · GitHub / GitLab writeup 인덱스 · 개인 블로그
1,800+ advisories	취약점 · 어드바이저리 — 버그바운티 · 벤더 어드바이저리 · CVE/PoC HackerOne Hacktivity · GitHub Security Advisory · NVD
30+ sets	데이터셋 · 방법론 — 평가셋 · 페이로드 코퍼스 · 테스트 가이드 Lakera PINT · HackAPrompt · OWASP AI Testing Guide · MITRE ATLAS

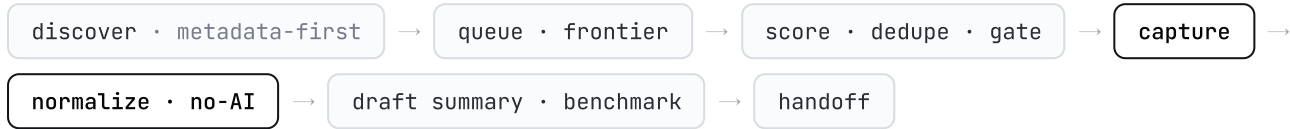


금지되는 방향 — Lab은 수집 큐 · SQLite · tmux · raw artifact를 변경하지 않고, 수집기는 Lab의 DB · 런타임을 쓰지 않으며, 소비자는 내부를 직접 읽지 않습니다.

// 02 · 수집 - ACQUISITION

어떻게 수집하나 — 발견부터 정규화까지.

발견은 metadata-first, 본문 캡처는 좁고 명시적입니다. 결정론적 정규화는 AI 없이 수행하고, 모든 단계는 다시 실행할 수 있도록 매니페스트를 남깁니다.



// CAPTURE - 본문은 두 갈래로만

exact public URL capture

명시적 공개 HTTP(S) URL만 캡처. host politeness · content type · size · auth/login wall · rate-limit을 검사하고, 그 외에는 metadata-only로 남깁니다.

public Git bundle fast path

GitHub/GitLab repo는 clone-first. 공개성 · 크기 · relevance · dedupe · shallow clone budget을 통과한 repo만 index · capture합니다.

// CANONICAL STATE - 진실은 매니페스트 (SQLITE는 재생성 가능한 PROJECTION)

Run 매니페스트

수집 출처 · 캡처 아티팩트 · metadata-only outcome (provenance).

Normalized 매니페스트

결정론적으로 추출된 텍스트와 source hash — 가공 대상.

Draft 요약 · 벤치마크

참고용 관찰값일 뿐, 정식 지식이 아님.



비실행 · 무우회 — 공개 PoC · 페이로드 · 명령 · 코드는 절대 실행하지 않으며, private · login-wall · rate-limit 우회를 하지 않습니다.

// 02 · 수집 - TOOL & TECHNIQUE KNOW-HOW

도구를 운영하지 않습니다. 그 방법을 추적합니다.

공개 보안 도구를 통합 · 실행하는 것이 아니라, 도구가 쓰는 공격 생성 · 평가 · 탐지 기법과 옵션 · 워크플로우 · 휴리스틱을 지속 추적해 근거 있는 지식으로 만듭니다. 위협 도메인별로 정리하면 다음과 같습니다.

60+	6	0
추적 도구 노하우	위협 도메인	직접 운영 · 실행

#	위협 도메인	추적하는 방법 · 노하우	대표 출처 도구
01	Jailbreak 탈옥 · 거부 우회	refusal 우회 · 적대적 프롬프트 생성 · 멀티턴 에스컬레이션	PAIR GCG EasyJailbreak ReNeLLM
02	Prompt Injection 프롬프트 인젝션	직접 · 간접 인젝션 · 시스템 프롬프트 유출 기법	Open-Prompt-Injection HouYi LLMInjector
03	RAG · Agent · Tool-use 에이전트 · 툴 악용	tool 응답 hijack · 권한 없는 함수 실행 평가 방법	AgentDojo Inspect Evals ARTKIT
04	MCP · Supply chain MCP · 공급망	tool metadata · skill · local config 점검 로직	Cisco MCP Scan Cisco Skill Scan agent-audit
05	Runtime defense 런타임 방어 · 탐지	입력 · RAG 문서 · 출력 검사 · 탐지 휴리스틱	LLM Guard Prompt Guard 2 Vigil PIGuard
06	Eval · Benchmark 평가 · 벤치마크	제일브레이크 판정 · 모델 위험 측정 방법론	JailbreakEval JAILJUDGE HarmBench CyberSecEval



도구는 다섯 수집 테마 중 하나 — 새 도구 · 기법이 등장하면 추적 대상에 추가되고, 그 노하우가 근거 스펠과 함께 지식으로 흡수됩니다. 실행 · 배포는 외부 분석 시스템의 몫입니다.

// 02 · 수집 — DATASETS & METHODOLOGY

데이터셋 · 페이로드 · 방법론까지 흡수합니다.

기법 · 라이트업뿐 아니라, 공개 데이터셋 · 벤치마크 · 페이로드 코퍼스 · 테스트 방법론을 읽기 전용으로 흡수해 탐지기 평가 · 테스트 시드 · 리포팅 매핑에 활용합니다. 공격에 바로 쓰일 수 있는 자료는 접근 통제된 환경에서 방어 검증 목적으로만 다룹니다.

// DATASETS — 데이터셋 · 벤치마크 (탐지기 · 가드레일 평가)

Lakera PINT

공개셋 과적합을 피한 인젝션 탐지 벤치마크.

NotInject

benign이지만 트리거 단어 포함 — 과방어 (FP) 평가.

HackAPrompt

600K+ 적대적 프롬프트 경진 데이터셋.

JailbreakBench

재현용 적대적 프롬프트 아티팩트 저장소.

In-The-Wild Jailbreak

실수집 15K 프롬프트 · 1.4K 제일브레이크.

deepset · xTRam1

탐지기 baseline 학습 · 평가용 라벨 데이터.

// PAYLOAD CORPORA — 페이로드 · 프롬프트 코퍼스 (테스트 시드 · 변형 후 사용)

PayloadsAllTheThings

PALLMs

Prompt-Injection-Everywhere

awesome-prompt-injection

Awesome-Jailbreak-on-LLMs

JailbreakZoo

// METHODOLOGY — 방법론 · 테스트 가이드 (테스트 케이스 · 표준 매핑)

OWASP AI Testing Guide

AITG-APP-01/02 — 직접 · 간접 프롬프트 인젝션 테스트 방법론.

OWASP Secure Agent Playbook

에이전트 인젝션 테스트 — Arcanum Taxonomy 기반 구조화.

OWASP Agentic Skills Top 10

에이전트 스킬 실행 레이어의 10대 위험 · 완화책.

MITRE ATLAS

AI/ML 공격 전술 · 기법 지식베이스 — 테스트 케이스 매핑.

LLM PI Prevention Cheat Sheet

instruction/data 분리 기반 방어 패턴 체크리스트.

// 03 · 가공 - EVIDENCE MODEL

근거까지 거슬러 추적되는, 5계층 코퍼스.

가져오기는 덮어쓰지 않는 append-first 읽기 전용입니다. 같은 문서를 다시 관측해도 기존 것을 덮지 않고 관측 · 텍스트 버전을 더하며, 청킹 정책이 바뀌어도 인용은 같은 원문 스패에 묶여 검증됩니다.

// CORPUS - DOCUMENTS → EVIDENCE SPANS

L1	documents 안정적 출처 식별	canonical · final URL, host, 상위 ID(CVE · GHSA · OSV · CTF), 제목, 텍스트 SHA-256, 근접 중복 지문, lane · record type으로 reconcile.
L2	document_observations 발견 · 캡처 관측 기록	같은 문서를 여러 번 본 기록 — source · final URL, 매니페스트 경로, record index, trust tier, sensitivity, 관측 시각.
L3	normalized_text_versions 버전드 텍스트 스냅샷	청킹 · LLM 처리의 입력. 텍스트 SHA-256과 scrub · access · risk · reality · export · LLM · execution 정책을 포함.
L4	chunks 검색 윈도우	검색 · 임베딩 단위. 청킹 정책이 바뀌면 언제든지 다시 생성할 수 있는 파생물.
L5	evidence_spans 인용 레이어	offset · span 해시 보존 → 청킹이 변해도 claim · answer · recipe · 스킴 후보가 같은 원문에 근거했는지 검증.

// POLICY DEFAULTS - 알 수 없으면, 막는다

access_tier	restricted	llm_visibility	external-blocked
export_policy	human-review-required	execution_policy	blocked

정책 라벨이 없거나 placeholder인 레코드는 분류 완료 또는 리뷰어 예외 전까지 일반 검색 · 원격 API/MCP 응답 · 내보내기 스냅샷에서 제외됩니다.

// SECURITY-AWARE EXTRACTION - 보안 특화 아티팩트 (실행 지시가 아닌 근거 레코드)

extracted_tips 재사용 가능한 휴리스틱 · 주의점 · 실전 인사이트.	extracted_payloads 페이로드 · HTTP 조각 · 파라미터 · PoC 스니펫을 검색 가능한 근거로 보관.	extracted_commands 도구 명령 예시 · 옵션 패턴.
code_artifacts solve 스크립트 · 익스플로잇 · 템플릿 · 패치 · 코드 예시.	http_trace_artifacts request/response 쌍과 프로토콜 트레이스.	artifact_evidence_refs 모든 추출 아티팩트를 원문 스패에 연결.

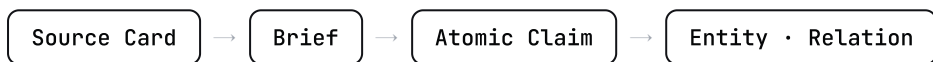
// 03 · 가공 - DISTILLATION

정규화 텍스트를, 타입드 지식으로.

덧어쓰지 않는 append-first 원칙으로, 정규화 · 분류 · 근거 앵커링을 거쳐 사람 리뷰 후 현재 서빙본 (current projection)으로 반영됩니다.



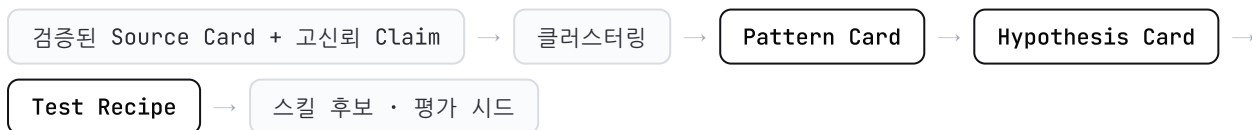
// LLM DISTILLATION - 디스틸레이션 체인



// KNOWLEDGE ARTIFACTS - 핵심 산출물



// CROSS-SOURCE SYNTHESIS - 교차 출처 합성, 한 단계 더



// 03 · 가공 - TRUST LIFECYCLE

한 번 만든 지식을, 시간이 지나도 신뢰할 수 있게.

캡처는 유효성으로 분류되고, 생성물은 덮어쓰지 않고 새 세대로 다시 만들어지며, 평가 게이트를 통과한 세대만 현재 서빙본(current projection)이 됩니다.

// VALIDITY - 캡처 유효성 분류

● valid

규칙을 통과했고 validity snapshot ID가 발급된 캡처.

● quarantine

지금은 부족하거나 의심스럽지만 나중에 살아날 수 있어 재검사 대상.

● terminal

영구 무효로 판단 — grace period 후 tombstone만 남길 수 있음.

● valid_revoked

과거엔 valid였으나 사후 회귀가 발견된 현재 row 상태.

snapshot은 단방향 — 사후 revoke가 있어도 그 시점의 과거 스냅샷 자체는 뒤집지 않으며, 현재 URL row만 다시 격리 · revoked 상태로 들어갑니다.

// REPROCESSING - 세대를 덮어쓰지 않는 6가지 재처리 모드

revalidate	새 생성 없이 스키마 · 근거 · 비평 · 정책 체크를 다시 수행.
repair	잘못된 JSON · 누락 필드 · 근거 앵커 · 정규화 문제를 고침.
refresh	새 모델 · 프롬프트 · 스키마 · 정책으로 같은 종류를 다시 생성.
migrate	기존 아티팩트를 새 스키마로 최소 해석 변환.
resynthesize	승인된 하위 아티팩트에서 패턴 · 가설 · 테스트를 재합성.
rollback	current projection을 이전 세대로 되돌림.

// EVAL - 무엇을 측정하나

검색 품질	답변 충실도	인용 정확도	미근거 주장을	엔티티 정규화	리뷰어 유용성	위험 지시 누출	롤백률
-------	--------	--------	---------	---------	---------	----------	-----

// 04 · 제공 - RETRIEVAL & STORAGE

하나의 ask가 아니라, 다섯 모드로.

조회를 하나로 뭉개지 않고 비용 · 지연 · 안전 · 감사 성격에 따라 모드를 분리합니다. LLM 자격이 없어도 일반 검색 · 하이브리드 검색이 동작합니다.

모드	LLM	도구 / 응답
G0	없음	풀텍스트 · 필터 — 결정론적 문서/아티팩트 목록
G1	없음	풀텍스트 + pgvector 하이브리드(생성 없음)
A1	재작성 · 재랭킹	retrieval 전용 — 랭킹된 출처 +why_matched
T1	계획 + 제한 합성	근거 번들 기반 인용 검증 답변/체크리스트
F0	없음	DB 없이 rg로 허용 파일 직접 탐색 — 로컬 운영자 triage



Postgres + pgvector

관계형 provenance + 풀텍스트 + 벡터 + 그래프.



아티팩트 스토어

텍스트 스냅샷 · 모델 요청/응답 · 비평 · 평가 · 내보내기 보관.



완전한 추적성

출처 URL · 문서 ID · 텍스트 버전 · 근거 스패 · 생성 ID 제시.



로컬 · 원격 분리

원격 응답은 경로 없는 안정 ID · 근거 번들 · 콘텐츠 해시만.

// 04 · 제공 - API · MCP · SKILL

사람과 에이전트 모두에게, 같은 근거를 안전하게.

정제된 지식은 안정적인 /v1 플랫폼 API와 remote-shaped MCP 툴, 내보내기 스냅샷, 그리고 다운스트림 Skill OS를 위한 evidence-backed 스킬 후보로 제공됩니다.

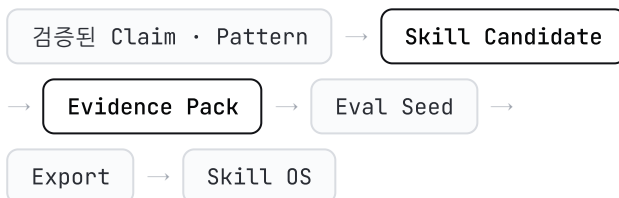
// PLATFORM API - /V1

import	POST /import/collector-manifest · GET /import/batches
documents	GET /documents · /documents/{id}
knowledge	/source-cards · /source-briefs · /claims · /entities/{id}/graph
distillation	POST /distill/source-card · brief · claims
search	POST /search/general · /search/ai · /evidence-tasks
artifacts	GET /artifacts/{tips,payloads,commands,code,http-traces}
skills	GET /skills/candidates · /skills/evidence-packs/{id}
review · export	POST /review/events · export · sanitized feedback

// MCP - 항상 REMOTE-SHAPED

- 응답은 항상 **remote-shaped** — 안정 ID · 스니펫 · 근거 번들만.
- filesystem 경로나 local_ref.path를 반환하지 않음.
- private DB · collector SQLite · tmux · raw artifact를 직접 읽지 않음.
- 안정 API capability(또는 동등 service handler)만 호출.

// SKILLIFICATION → SKILL OS



스킬 후보는 반드시 evidence-backed — applicability · preconditions · procedure outline · failure modes · safety constraints · output contract · eval seed, canonical skill registry와 배포는 다운스트림 Skill OS의 책임입니다.



피드백 루프 — 다운스트림은 sanitized case card · skill usage · retrieval label · eval 결과만 되돌려보내며, 즉시 지식이 되지 않고 review · eval · refresh 큐로 들어갑니다.

// 05 - SAFETY & TRUST

신뢰는 기본값이 아니라, 설계입니다.

원본을 신뢰하지 않는 것에서 출발합니다. 위험 자료는 격리하고, 분류 전에는 차단하며, 사람의 검증 없이는 승격하지 않습니다.



원본 자료는 신뢰하지 않음

캡처된 코드 · 익스플로잇 · 페이로드 · 명령을 제품이 실행하지 않습니다.



원본은 명령이 아니라 데이터

LLM 프롬프트는 source text를 untrusted 데이터로만 다루고, material claim은 근거 스펠을 인용 — 검증 실패 시 reject · downgrade · review로 보냅니다.



기본 차단 (default restricted)

분류되지 않은 레코드는 외부 차단 · 실행 차단이 기본값입니다.



CTF · 랩 파생 자료의 경계

가설은 줄 수 있어도, 실제 타깃의 증거가 될 수 없습니다.



승격 통제

컬렉터 Draft 요약은 검증 · 비평 · 리뷰 없이 정식 지식으로 승격되지 않습니다.



T1은 자율 에이전트가 아님

근거 태스크는 live 타깃 동작 · 셸 실행 · exploit 실행을 하지 않습니다 — 런타임 실행은 외부 control plane의 책임입니다.

// SUMMARY

수집하고, 가공하고, 안전하게 제공합니다.

Knowledge Lab은 공개 보안 생태계의 **기법과 노하우** — 도구 · 기법 · CTF · 취약점 · 데이터셋 — 를 추적 · 수집하고, 출처 · 근거 · 정책 · 버전이 끝까지 추적되는 **타임드 지식으로 가공**해, 사람과 에이전트 모두에게 안전한 검색 · RAG · MCP로 **제공**하는 플랫폼입니다.

도구는 운영 대상이 아니라 **추적 대상**입니다. 다섯 갈래의 공개 출처가 하나의 신뢰 가능한 지식 코어로 수렴하고, 단일 **API · MCP · Skill** 표면으로 흘러나갑니다.

PLATFORM

Knowledge Lab
SAFE SQUARE AI Labs

CONTACT

contact@ssq.ai
1 Finlayson Green #18-01
Singapore 049246

[SSQ.AI]

© 2026 SAFE SQUARE PTE. LTD.
ssq.ai · AI Security · Singapore